Insight Assurance

Delivering Quality, Assuring Trust.

System and Organization Controls Report (SOC 2® Type 2)

Report on OpenAI OpCo, LLC's Description of Its ChatGPT and API Services and on the Suitability of the Design and Operating Effectiveness of Its Controls Relevant to Security and Confidentiality Throughout the Period July 1, 2024, to December 31, 2024

OpenAI

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.696Z

SAFEBASE

TABLE OF CONTENTS

SECTION 1: INDEPENDENT SERVICE AUDITOR'S REPORT **1**

INDEPENDENT SERVICE AUDITOR'S REPORT 2

SECTION 2: OPENAI OPCO, LLC'S MANAGEMENT ASSERTION **6**

OPENAI OPCO, LLC'S MANAGEMENT ASSERTION 7

SECTION 3: OPENAI OPCO, LLC'S DESCRIPTION OF ITS CHATGPT AND API SERVICES **9**

OPENAI OPCO, LLC'S DESCRIPTION OF ITS CHATGPT AND API SERVICES 10

SECTION 4: TRUST SERVICES CATEGORIES, CRITERIA, RELATED CONTROLS, AND TESTS OF CONTROLS **21**

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY 23

ADDITIONAL CRITERIA FOR THE CONFIDENTIALITY CATEGORY 72

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59Z

SECTION 1: INDEPENDENT SERVICE AUDITOR'S REPORT

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.696Z

Insight Assurance
Delivering Quality, Assuring Trust.

INDEPENDENT SERVICE AUDITOR'S REPORT

To: OpenAI OpCo, LLC

Scope

We have examined OpenAI OpCo, LLC's ("OpenAI" or "the service organization") accompanying description of its ChatGPT and API Services found in Section 3 titled "OpenAI OpCo, LLC's description of its ChatGPT and API Services" throughout the period July 1, 2024, to December 31, 2024 ("description") based on the criteria for a description of a service organization's system set forth in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance—2022)* in AICPA, *Description Criteria*, (description criteria) and the suitability of the design and operating effectiveness of controls stated in the description throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved based on the trust services criteria relevant to Security and Confidentiality (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)* in AICPA*, Trust Services Criteria.*

OpenAI uses Microsoft Azure, Snowflake, Okta, and WorkOS ("subservice organizations") to provide hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at OpenAI, to achieve OpenAI's service commitments and system requirements based on the applicable trust services criteria. The description presents OpenAI's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of OpenAI's controls. The description does not disclose the actual controls at the subservice organizations. Our examination did not include the services provided by the subservice organizations, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that certain complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at OpenAI, to achieve OpenAI's service commitments and system requirements based on the applicable trust services criteria. The description presents OpenAI's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of OpenAI's controls. Our examination did not include such complementary user entity controls, and we have not evaluated the suitability of the design or operating effectiveness of such controls.

Service Organization's Responsibilities

OpenAI is responsible for its service commitments and system requirements and designing, implementing, and operating effective controls within the system to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved. In Section 2, OpenAI has provided the accompanying assertion titled "OpenAI OpCo, LLC's Management Assertion" (assertion) about the description and the suitability of the design and operating

A.Sai Nandan (nsai@openaiopco.onmicrosoft.com) 2025-01-17T16:06:15.096Z

effectiveness of controls stated therein. OpenAI is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria, and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

We are required to be independent and meet our other ethical responsibilities in accordance with ethical requirements relating to the examination engagement.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves—

- obtaining an understanding of the system and the service organization's service commitments and system requirements.
- assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively.
- performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria.
- performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- evaluating the overall presentation of the description.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual report users may consider

Asad Nansoor - esd@cloudcontrolstudio.com - 2025-04-17T16:08:50.096Z

important to meet their informational needs. There are inherent limitations in any system of internal control, including the possibility of human error and the circumvention of controls. Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Test of Controls

The specific controls we tested, and the nature, timing, and results of those tests are listed in Section 4.

Opinion

In our opinion, in all material respects,

- the description presents OpenAI's ChatGPT and API Services that were designed and implemented throughout the period July 1, 2024, to December 31, 2024, in accordance with the description criteria.
- the controls stated in the description were suitably designed throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements would be achieved based on the applicable trust services criteria if its controls operated effectively throughout that period and if the subservice organizations and user entities applied the complementary controls assumed in the design of OpenAI's controls throughout that period.
- the controls stated in the description operated effectively throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved based on the applicable trust services criteria if complementary subservice organization controls and user entity controls assumed in the design of OpenAI's controls operated effectively throughout that period.

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4, is intended solely for the information and use of management of OpenAI; user entities of OpenAI's ChatGPT and API Services during some or all of the period July 1, 2024, to December 31, 2024; business partners of OpenAI subject to risks arising from interactions with the ChatGPT and API Services; practitioners providing services to such user entities and business partners; prospective user entities and business partners; and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization.
- How the service organization's system interacts with user entities, business partners, and other parties.
- Internal control and its limitations.

Asad Nasser, asad@openaiopinions.com, 2025-04-11T16:08:59.696Z

- Complementary user entity controls and complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements.
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services.
- The applicable trust services criteria.
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks.

This report is not intended to be, and should not be, used by anyone other than the specified parties.

Insight Assurance LLC

Tampa, Florida
February 21, 2025

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:50.695Z

SECTION 2: OPENAI OPCO, LLC'S MANAGEMENT ASSERTION

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.696Z

OpenAI

OPENAI OPCO, LLC'S MANAGEMENT ASSERTION

We have prepared the description of OpenAI OpCo, LLC's ("OpenAI" or "the service organization") ChatGPT and API Services entitled "OpenAI OpCo, LLC's description of its ChatGPT and API Services" throughout the period July 1, 2024, to December 31, 2024 ("description") based on the criteria for a description of a service organization's system set forth in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance—2022)* in AICPA, *Description Criteria*, (description criteria). The description is intended to provide report users with information about the ChatGPT and API Services that may be useful when assessing the risks arising from interactions with OpenAI's system, particularly information about system controls that OpenAI has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to Security and Confidentiality (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)* in AICPA, *Trust Services Criteria.*

OpenAI uses Microsoft Azure, Snowflake, Okta, and WorkOS (the "subservice organizations") to provide hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at OpenAI, to achieve OpenAI's service commitments and system requirements based on the applicable trust services criteria. The description presents OpenAI's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of OpenAI's controls. The description does not disclose the actual controls at the subservice organizations.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at OpenAI, to achieve OpenAI's service commitments and system requirements based on the applicable trust services criteria. The description presents OpenAI's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of OpenAI's controls.

We confirm, to the best of our knowledge and belief, that:

- the description presents OpenAI's ChatGPT and API Services that were designed and implemented throughout the period July 1, 2024, to December 31, 2024, in accordance with the description criteria.
- the controls stated in the description were suitably designed throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements would be achieved based on the applicable trust services criteria, and if the subservice organizations and user entities applied the complementary controls assumed in the design of OpenAI's controls.

Asal Nassoor, asal@cpacontrols.com 2025-04-17T 6:00:30.0052

- the controls stated in the description operated effectively throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved based on the applicable trust services criteria if complementary subservice organization controls and complementary user entity controls assumed in the design of OpenAI's controls operated effectively throughout that period.

OpenAI OpCo, LLC
February 21, 2025

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.696Z

SECTION 3: OPENAI OPCO, LLC'S DESCRIPTION OF ITS CHATGPT AND API SERVICES

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.696Z

OPENAI OPCO, LLC'S DESCRIPTION OF ITS CHATGPT AND API SERVICES

Company Background

OpenAI OpCo, LLC ("OpenAI") is a privately held company established in September 2020, specializing in natural language processing. OpenAI provides advanced language model services through its API and ChatGPT, a conversational platform. Headquartered in San Francisco, CA, OpenAI is a Delaware limited liability company.

Services Overview

OpenAI develops foundation models and makes their capabilities available to business users through two main services: the Application Programming Interface ("API") Platform and the business suite of ChatGPT applications ("ChatGPT"), including ChatGPT Team, ChatGPT Enterprise, and ChatGPT Edu ("ChatGPT and API Services"). The consumer version of ChatGPT is excluded from this service description.

API

OpenAI's API Platform enables developers to integrate the capabilities of our models into their own applications. The API can be utilized for a wide range of tasks involving the understanding or generation of natural language, code, and other content. OpenAI offers a range of models with different capabilities and price points, along with the ability to fine-tune custom models to meet specific needs.

ChatGPT

OpenAI's ChatGPT Services allows users to interact with OpenAI's models through a conversational interface. Users can request the models to analyze or generate text and code or create images based on text descriptions. ChatGPT is available for business users as ChatGPT Team, ChatGPT Enterprise, and ChatGPT Edu. Business services include robust security controls, with ChatGPT Enterprise providing additional features such as SAML Single Sign On (SSO), enhanced administrative controls, and priority support.

OpenAI maintains consistent security commitments across all its services. By default, OpenAI does not use business data for training our models. Both ChatGPT Enterprise and the API provide enterprise-level authentication. Additionally, all OpenAI services offer fine-grained control over access and features, including the customization of models developed by users.

User Interface

Web – Accessible via any modern browser for ChatGPT conversations

Desktop – Available on macOS and Windows for content creation, coding, and research

Mobile – Available on iOS and Android for on-the-go interaction

API – Integrates with custom applications for programmatic access to language models

Fazal Mansoor Syed@cloudcontrolstudio.com 2025-04-11T16:09:19.696Z

PRINCIPAL SERVICE COMMITMENTS AND SYSTEM REQUIREMENTS

OpenAI designs its processes, procedures, and controls for ChatGPT and API Services ("System") to meet its service commitments, legal and regulatory requirements, and internal standards. Security commitments are detailed in customer agreements and online service descriptions, and include:

- **Logical Access Control**: Security principles are embedded in the core designs of OpenAI's Services to ensure system users can access only the information necessary for their roles, preventing unauthorized access to data not pertinent to their functions.
- **Encryption**: Customer data is protected with encrypted technologies both at rest and in transit, ensuring secure communication between customers and the System, as well as between the System and service providers.
- **Data Retention and Disposal:** Data retention and disposal processes are aligned with OpenAI's retention policies and are executed upon customer initiation or request.

Operational requirements support security, legal, and regulatory compliance and are communicated through policies, system design documentation, and customer agreements. Information security policies cover system design, development, operation, and employee management. OpenAI specifies processes for the operation and development of the System.

Scope of the Description

This description pertains only to OpenAI OpCo, LLC's ChatGPT and API Services. It excludes other services by OpenAI OpCo, LLC.

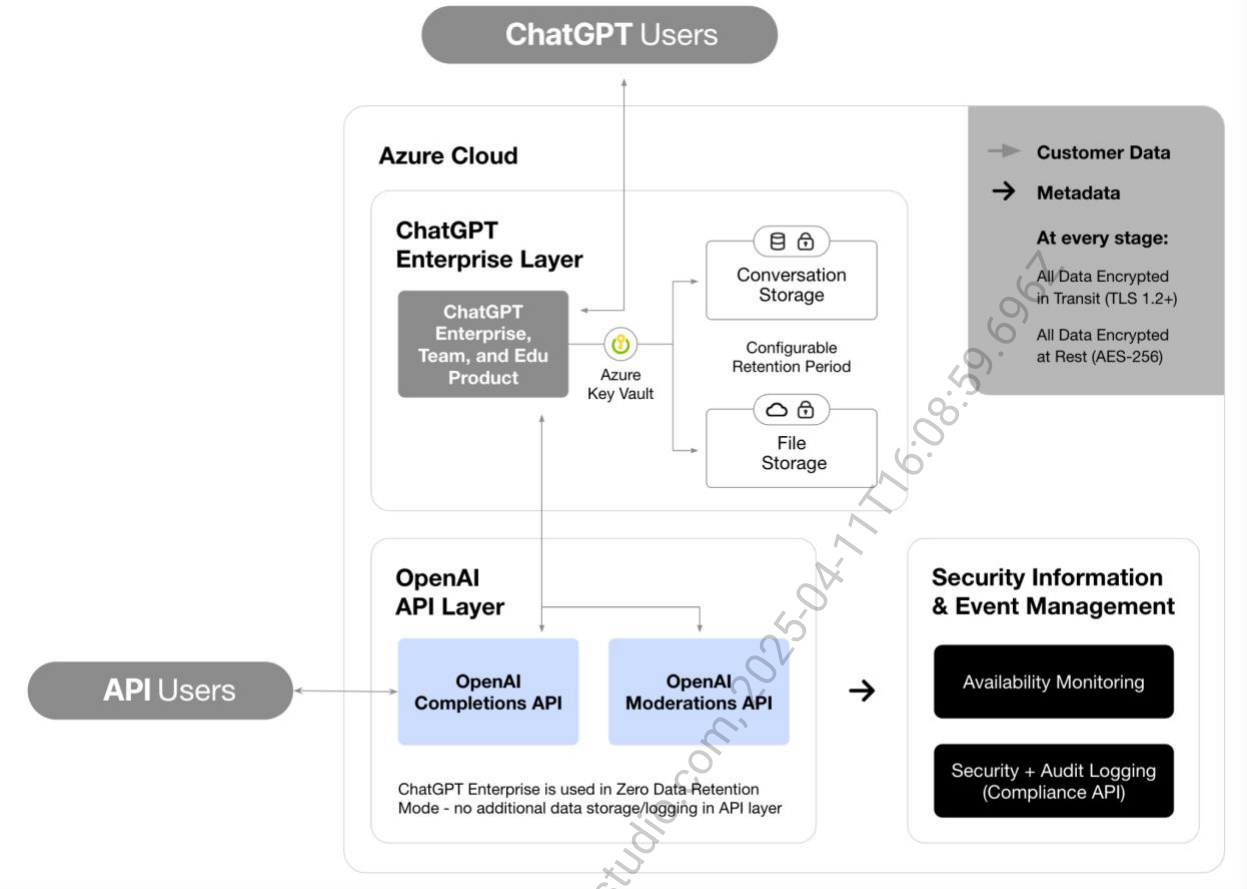
INFRASTRUCTURE

OpenAI's ChatGPT and API Services are deployed in a multi-tenant architecture. The System's application infrastructure is hosted by both Microsoft Azure and Snowflake, which provide scalable cloud hosting and data warehousing services as subservice organizations. Azure Cloud Services manage physical security, environmental protection, and network security with advanced firewall and network protection capabilities.

OpenAI's Information Security Policy ensures that workstations and servers are equipped with appropriate security software and regularly updated with the latest patches. In the event of security threats, automated systems respond with quarantine or removal actions, as necessary. If needed, infected machines are isolated from the network for remediation. The IT and Security departments jointly maintain defenses and monitor vulnerabilities across the network and application infrastructure, adhering to established SLAs.

Security monitoring includes multiple layers of traffic detection for malicious content. Third-party penetration tests are conducted annually to identify vulnerabilities and assess the security of production systems. Additionally, all employee workstations meet minimum security standards, and backup workstations are maintained to minimize operational disruptions.

Asad Malik, asad@ldlcontrolstudio.com, 2025-04-11 16:03:59 UTC



ChatGPT and API

SOFTWARE

OpenAI maintains an up-to-date inventory of critical software used in its environment, ensuring all necessary software licenses are documented. Key software components include the following:

Third Party Software	
Software	**Description**
Microsoft Entra ID	Identity and access management service
Tailscale	VPN
Buildkite	Continuous integration service
CrowdStrike Falcon	Endpoint protection
Databricks	SIEM
Cloudflare	Firewall
Datadog	System Monitoring
GitHub	Source code management
Isovalent Cilium	Intrusion detection system/intrusion prevention system (IDS/IPS)

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.6967

Third Party Software	
Software	**Description**
Jamf	Mobile device management solution
Jira	Ticketing system
Wiz	Vulnerability scanner

PEOPLE

OpenAI employs dedicated teams for all major product functions, including development, operations, and support, organized into the following functional areas:

- **Executive Leadership**: Responsible for setting the vision, mission, and values of OpenAI, as well as overseeing the strategic direction, governance, and compliance of the organization. Also responsible for ensuring alignment of HR policies, practices, and processes with OpenAI's culture and objectives.
- **Applied Engineering**: Responsible for developing, testing, deploying, and maintaining OpenAI's API and ChatGPT Services, as well as other AI applications and services. Also responsible for adhering to security, quality, and performance standards throughout the software development lifecycle.
- **IT**: Responsible for managing and maintaining OpenAI's IT corporate infrastructure, systems, and networks, as well as providing technical support and guidance to users. Also responsible for implementing and enforcing security controls, policies, and procedures to protect OpenAI's data and assets.
- **Security**: Oversees the implementation of information security controls for infrastructure and IT processes; responsible for the design, development, implementation, operation, maintenance, and monitoring of cyber security controls; communicates information security risks to executive leadership.
- **People Operations Team**: Responsible for recruiting, hiring, onboarding, and retaining OpenAI's employees, as well as providing payroll, benefits, and performance management services. Also responsible for fostering a diverse, inclusive, and ethical work environment, as well as promoting OpenAI's values and culture.

DATA

OpenAI defines Customer Data as the electronic data or information submitted by the Customer or Authorized Parties to OpenAI's service. Customer data is securely managed, processed, and stored in compliance with relevant data protection regulations and established customer agreements. Customer Data is utilized by OpenAI in delivering its API Platform and ChatGPT Services. Customer Data is stored following industry best practices. Access to this data is restricted by technical and policy controls, and limited to employees whose job function requires it, in accordance with OpenAI's Privacy Policy and Terms of Use. All data managed, processed, or stored by OpenAI is subject to an internal classification system defined in our Data Management Policy.

Asad Mansoor, asad@cloudcontrolstudio.com, 20250404-171608:59696Z

All employees and contractors of OpenAI are obligated to respect and, in all cases, to protect customer data. Customer information, employment-related records, and other intellectual property-related records are subject to limited exceptions, confidential as a matter of law, and employment agreements signed by OpenAI employees. Many other categories of records, including Company and other personnel records and records relating to OpenAI's business and finances, are, as a matter of OpenAI policy, treated as confidential. Responsibility for guaranteeing appropriate security for data, systems, and networks is shared by the Applied Engineering, IT, and Security departments. IT and Security are responsible for designing, implementing, and maintaining security protection of the data. They also retain responsibility for ensuring compliance with the policy. In addition to management and the technology staff, individual users are responsible for the equipment and resources under their control.

OpenAI has policies and procedures in place to ensure proper retention and disposal of customer data. The retention and data destruction policies define the retention periods and proper destruction procedures for the disposal of data. These policies are reviewed at least annually. ChatGPT Enterprise customers can configure a retention window, with a minimum period of 90 days. For all Services, deleted data will be removed from our system within 30 days, after the data is marked for deletion, regardless of the selected retention period. In addition, customer data is never used in the development or training of new models.

The confidentiality of electronic communications is secured to a high standard. Networks are protected by enterprise-class firewalls and appropriate enterprise-class virus protection is in place. Password protection with assigned user rights is required for access to the network, application, and databases. Access to the network, application, and databases is restricted to authorized internal and external users of the System to prohibit unauthorized access to confidential data.

OpenAI uses centrally managed role-based access control and requires users to be authenticated prior to the use of any resources. Users' access requests for resources are validated against the user's authorized roles in Microsoft Entra ID. Employees are authenticated using multi-factor authentication. Additional access controls include the broad use of single sign-on, device certificates for single sign-on, and tools to defend against phishing, malware, and other risks borne from general web activity.

PROCEDURES

Management has developed formal IT policies and procedures that describe logical access, computer operations, change management, incident management, vulnerability management, and data communication standards to obtain the stated objectives for network and data security, data privacy, and integrity for both the Company and its customers and define how services should be delivered. These are communicated to employees and are located within the organization's intranet. OpenAI reviews and updates its policies and procedures as required, at least annually.

Reviews and changes to these policies and procedures are performed annually and are approved by senior management.

Asad Nanjoor, asad@cloudcontrolstudio.com 2025-04-17 16:08:39 6167

Physical Security and Environmental Controls

Azure and Snowflake, as the subservice provider hosting services, are responsible for implementing physical security controls over data centers for in-scope systems.

Logical Access

OpenAI has taken steps to centralize and secure its identity and access management services. These controls include mandatory multi-factor authentication for employees, broad use of single sign-on (SSO), device certificates for SSO, and tools to defend against phishing, malware, and risks borne from general web activity. OpenAI uses role-based access control architecture and requires users of the System to be identified and authenticated prior to the use of any resources. Resources are protected through an identity management solution that identifies, authenticates, and validates access requests against the user's authorized roles in Microsoft Entra ID. Elevated privileges are limited by role, require approval, time limited, and logged.

Logical access to OpenAI's networks, applications, and data is limited to properly authorized individuals. For OpenAI employee authentication, logical access is controlled via mandatory multi-factor authentication. For customer authentication, logical access is controlled via standard user authentication credentials (user ID and password). API Platform and ChatGPT Enterprise customers can leverage single sign-on. ChatGPT for business administrators can also leverage the Admin Dashboard to centralize and manage user access for their workspace.

Change Management

OpenAI maintains documented Secure Development policies and procedures to provide appropriate oversight and documentation for application and infrastructure changes. Change management procedures include change request and initiation processes, documentation requirements, development practices, testing requirements, required approval, and planned upgrade and maintenance procedures. OpenAI uses code versioning software for source control management and makes changes to its repositories via pull requests. The documentation of change management procedures is maintained in our source code platform.

In the event of an emergency, change management procedures are still applied but on an accelerated timeline. Documentation occurs but may be outside the typical location in our source code platform. Additionally, OpenAI maintains rollback capabilities to minimize the impact of change-related incidents, such as errors, defects, outages, or breaches.

Patch Management

The Security Team monitors advanced notifications of bug-related patches that are disclosed prior to a public announcement by the vendor. The IT, Security, and Applied Engineering teams review the availability of patches and independently determine if they are necessary to deploy within the production environment. Approved patches are scheduled for installation in the staging environment. If there are no issues in the staging environment, the patch will be applied to the production environment. The patching process is tracked and documented.

Fahad Mansour, fahad@cloudcontrolsstudio.com, 2025-04-11 17:18:45 UTC

Incident and Vulnerability Management

OpenAI maintains an Incident Response Plan that describes the process for identifying and addressing potential security incidents. The policy details steps to take if an incident is suspected. Plans for detecting, responding to, and recovering from incidents are included in the policy, and post-incident activity requirements are defined. To ensure that responsible employees are prepared to respond to incidents, the organization conducts incident response exercises.

The organization provides a Bug Bounty Program where customers can report potential security vulnerabilities, and customers are also provided with an email for this same purpose. Internal users are directed to report incidents through an internal portal for documentation and tracking purposes.

System Monitoring

The Operations Security Policy describes the organization's policies and procedures related to network and system logging, monitoring, as well as vulnerability identification and remediation. The organization uses Azure logs from Azure services for system logging, and the organization collects logs from systems throughout its environments. Azure and application logs document source IP, destination IP, destination port, protocol type, and timestamp. The organization monitors system capacity to ensure availability. Logs are aggregated in Databricks and OpenAI runs custom queries to detect and respond to security events.

Cloudflare and custom Cilium network policies and logs are used for threat detection purposes. The tools used generate logs, network telemetry, and DNS logs for intrusion detection.

The vulnerability assessment process involves continuous monitoring of endpoints with antivirus and vulnerability scanning software, including system patching of third-party dependencies. The organization uses CrowdStrike Falcon endpoint protection and has configured the software to run updates daily and prohibit end-users from disabling the software. The organization uses Wiz vulnerability management and alerting. Alerts are sent immediately when a potential virus or vulnerability is detected, and logs are generated and retained.

Vendor Management

The organization maintains a Third-Party Management Policy that includes requirements for interacting with third party vendors. The policy includes requirements for performing due diligence measures prior to engaging with new vendors. Due diligence procedures include evaluating each vendor's functionality, services, risk, security, compliance, and performance. The organization monitors its vendors' compliance with the agreed upon security and confidentiality agreements. The organization executes non-disclosure agreements with third parties before any information is shared.

Asad Nanabor, asad@cloudsecurityprodstudio.com, 2026-04-11T16:08:50.969Z

RELEVANT ASPECTS OF THE CONTROL ENVIRONMENT, RISK ASSESSMENT PROCESS, CONTROL ACTIVITIES, INFORMATION AND COMMUNICATION, AND MONITORING

CONTROL ENVIRONMENT

The control environment is the set of standards, processes, and structures that provide the basis for carrying out internal control across an organization. The organizational structure, separation

of job responsibilities by departments and business function, documentation of policies and procedures, and internal audits are the methods used to define, implement, and assure effective operational controls. The Board of Directors and/or senior management establish the tone at the top regarding the importance of internal control and expected standards of conduct.

Management Philosophy, Integrity, and Ethical Values

OpenAI's control environment reflects the philosophy of senior management concerning the importance of the security of data. Management is responsible for setting the tone at the top, establishing, communicating, and monitoring control policies and procedures.

Formal policies and a Code of Conduct are documented and communicated to employees to ensure that organizational values, ethics, integrity, and behavioral standards are a primary focus, and risks are mitigated in daily operations.

OpenAI emphasizes the importance of the security of data to ensure processing integrity is a primary focus and that controls are maximized to mitigate risk in daily operations.

Formal job descriptions, department meetings, and personnel interactions ensure communication of organizational values, ethics, and behavior standards. Personnel operate under OpenAI's policies and procedures, including confidentiality agreements and security policies. New hires receive annual security awareness training upon hire and annually thereafter. Management stays abreast of regulatory, economic, and market changes that may impact the business or OpenAI's customers.

Commitment to Competence

OpenAI has standardized people operations policies and procedures which create a uniform set of practices that provide equitable hiring and advancement opportunities across the organization.

Training and development opportunities are available to personnel and performance evaluations are performed to communicate goals based on job responsibilities and address any performance issues.

These policies and procedures are available to personnel. Management communicates material changes to these policies and policies are updated as needed. To protect confidential internal information and customer data, employees are prohibited from sharing information regarding customer engagements.

People Operations Policies and Procedures

OpenAI has formal hiring procedures designed to ensure new team members can perform the job requirements and responsibilities. Candidates undergo interviews, and assessments of their education, professional experience, and certifications. Background checks are performed for new employees before their start date and include a review of their criminal records.

During the onboarding process, new employees review the Code of Conduct and any other relevant policies and procedures relevant to their role. New employees are required to review and acknowledge the Code of Conduct. These policies and procedures are available to employees

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.895Z

through internal document stores. Employees are also required to complete security and privacy awareness training at least annually.

Ongoing performance feedback is provided to employees. Formal performance reviews are completed annually by management to discuss expectations, goals, and the employees' performance for the last year.

RISK ASSESSMENT PROCESS

OpenAI has established a risk assessment process to identify, analyze, mitigate, and manage risks relevant to its services and organization. Various types of risks are considered, including, but not limited to, operational, strategic, technological, compliance, security, and vendor risks. Risk treatment plans and control activities serve as mechanisms for mitigating identified risks and help to ensure OpenAI achieves its security commitments.

OpenAI performs an annual risk assessment to identify, assess, and plan for risks that could affect the organization's ability to provide reliable services to its customers. It includes the identification of key business processes where potential exposures of consequence exist, as well as significant changes to those processes. Once impact and likelihood have been assessed, management considers how risks should be managed. This involves judgment based on assumptions about and analysis of the risk and reasonable analysis of costs and resources associated with reducing the level of risk. Necessary actions are taken, and controls are identified to reduce the significance or likelihood of the risk occurring.

INFORMATION AND COMMUNICATION SYSTEM

OpenAI's Information Security Policy ensures employees understand their security roles and responsibilities. This includes both formal and informal training programs, as well as communication tools like email and Slack for timely dissemination of security-related information and processes, ensuring key personnel are promptly notified of any issues. OpenAI reviews and updates its Information Security Policy as required, at least annually.

Additional communication methods include department meetings to communicate company policies, procedures, industry or business issues, or other topics management deems key to the achievement of the Company's objectives. Communication is encouraged at all levels to promote the operating efficiency of OpenAI.

OpenAI also updates their website and documentation on an ongoing basis to inform customers and other external parties of industry-related issues that could impact the System and steps the Company is taking to reduce or avoid impact on operations. The organization's security commitments regarding the services are included in the services agreement.

MONITORING CONTROLS

Management employs monitoring software to ensure system security, supplementing oversight, and vulnerability assessments. Ongoing monitoring of internal controls is also conducted by management.

Asad Nanson, asad@cloudcomplstudio.com, 2025-04-11T16:58:59.096Z

Monitoring of the Subservice Organization

OpenAI uses Microsoft Azure and Snowflake for cloud hosting services and data warehousing services. Okta provides the services to authenticate customer access to the services. Customers can elect to use WorkOS to manage cross-domain identities.

OpenAI management reviews subservice organization compliance reports on an annual basis. These reviews were last performed in June 2024. In addition, through operational activities, OpenAI management monitors subservice organization services to ensure that operations and controls are implemented and operating effectively.

CHANGES TO THE SYSTEM DURING THE PERIOD

No significant changes have occurred to the services provided to user entities during the examination period.

SYSTEM INCIDENTS DURING THE PERIOD

No significant system incidents have occurred to the services provided to user entities during the examination period.

COMPLEMENTARY SUBSERVICE ORGANIZATION CONTROLS (CSOCs)

OpenAI's controls related to the system cover only a portion of overall internal control for each user entity of OpenAI. It is not feasible for the trust services criteria related to the system to be achieved solely by OpenAI. Therefore, each user entity's internal controls should be evaluated in conjunction with OpenAI's controls and the related tests and results described in Section 4 of this report, taking into account the related complementary subservice organization controls expected to be implemented at the subservice organizations as described below.

#	Complementary Subservice Organization Controls (CSOC)	Related Criteria
1	Microsoft Azure and Snowflake are responsible for maintaining physical security and environmental protection controls over the data centers hosting the OpenAI infrastructure.	CC6.4
2	Microsoft Azure and Snowflake are responsible for the destruction of physical assets hosting the production environment.	CC6.5
3	Okta is responsible for managing customer authentication and maintaining logical and physical protection controls of the customer authentication infrastructure.	CC6.1 and CC6.4
4	If elected by the customer, WorkOS is responsible for providing cross-domain identity management and maintaining logical and physical protection controls of the customer authentication infrastructure.	CC6.1 and CC6.4

COMPLEMENTARY USER ENTITY CONTROLS (CUECs)

OpenAI's controls related to the ChatGPT and API Services only cover a portion of the overall internal controls for each user entity. It is not feasible for the applicable trust services criteria

Asad Ansari asad@safebase.io 2025-04-11T16:08:59.696Z

related to the system to be achieved solely by OpenAI's control procedures. Accordingly, user entities, in conjunction with the services, should establish their internal controls or procedures to complement those of OpenAI.

User auditors should determine whether the following controls have been in place in operation at the user organization:

#	Complementary User Entity Controls (CUEC)	Related Criteria
1	User entities are responsible for controls to provide reasonable assurance that user access, including the provisioning and deprovisioning, are designed appropriately and operating effectively.	CC6.1, CC6.2, and CC6.3
2	User entities are responsible for reporting issues with OpenAI's systems and platforms.	CC2.3, CC7.3, and CC7.4
3	User entities are responsible for understanding and complying with their contractual obligations to OpenAI.	CC2.3
4	User entities are responsible for notifying OpenAI of changes made to the administrative contact information.	CC2.3

TRUST SERVICES CATEGORIES, CRITERIA, AND RELATED CONTROLS

The Security and Confidentiality categories and applicable trust services criteria were used to evaluate the suitability of the design of controls stated in the description. The criteria and controls designed, implemented, and operated to meet them ensure that information, systems, and access (physical and logical) are protected against unauthorized access, and systems are available for operation and use. The controls supporting the applicable trust services criteria are included in Section 4 of this report and are an integral part of the description of the system.

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59+0000

SECTION 4: TRUST SERVICES CATEGORIES, CRITERIA, RELATED CONTROLS AND TESTS OF CONTROLS

Asad Mansoor, asad@cloudcomplestudio.com, 2025-04-11T16:08:59.696Z

TRUST SERVICES CATEGORIES, CRITERIA, RELATED CONTROLS, AND TESTS OF CONTROLS

This SOC 2 Type 2 report was prepared in accordance with the AICPA attestation standards and has been performed to examine the suitability of the design and operating effectiveness of controls to meet the criteria for the Security and Confidentiality categories set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (*With Revised Points of Focus—2022)* in AICPA*, Trust Services Criteria* throughout the period July 1, 2024, to December 31, 2024.

The applicable trust services criteria and related controls specified by OpenAI are presented in Section 4 of this report.

Test procedures performed in connection with determining the operating effectiveness of controls detailed here in Section 4 are described below:

- Inquiries – Inquiry of appropriate personnel and corroboration with management.
- Observation – Observation of the application, performance, or existence of the control.
- Inspection – Inspection of documents and reports indicating the performance of the control.
- Reperformance – Reperformance of the control.

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T11:08:59.696Z

CONTROL ACTIVITIES SPECIFIED BY THE SERVICE ORGANIZATION

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ENVIRONMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC1.1 - COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.			
CC1.1.1	The company has an approved Code of Conduct that is reviewed annually and updated as needed. Sanction policies are documented within the information security policies and procedures.	Inspected the company's Code of Conduct to determine that the company had an approved Code of Conduct that was reviewed annually and updated as needed.	No exceptions noted.
		Inspected the company's information security policies and procedures to determine that sanction policies were documented within the information security policies and procedures.	No exceptions noted.
CC1.1.2	The company requires employees and contractors to acknowledge the Code of Conduct at the time of hire.	Inspected the Code of Conduct acknowledgment for a sample of new employees and contractors to determine that the Code of Conduct was acknowledged at the time of hire.	No exceptions noted.
CC1.1.3	The company requires employees and contractors to review and acknowledge the information security policies at the time of hire.	Inspected the information security policies acknowledgment for a sample of new employees and contractors to determine that the information security policies were acknowledged at the time of hire.	No exceptions noted.
CC1.1.4	The company's managers are required to complete performance evaluations for direct reports at least annually.	Inspected the completed performance evaluation for a sample of employees to determine that the company's managers were required to complete performance evaluations for direct reports annually.	No exceptions noted.

Raul Mansoor Sayed@cloudcompliance.com 2025-04-17T16:08:59.696Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ENVIRONMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC1.1.5	The company performs background checks on new employees.	Inspected the completed background check for a sample of new employees to determine whether the company performed background checks on new employees.	No exceptions noted.
CC1.1.6	Employees and contractors are required to review and acknowledge the confidentiality agreement at the time of hire.	Inspected the signed contractor agreements and non-disclosure agreements for a sample of new employees and contractors to determine that employees and contractors were required to review and acknowledge the confidentiality agreement at the time of hire.	No exceptions noted.
CC1.2 - COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.			
CC1.2.1	The company's board members have sufficient expertise to oversee management's ability to design, implement and operate information security controls.	Inspected the board members' profiles to determine that the company's board members had sufficient expertise to oversee management's ability to design, implement and operate information security controls.	No exceptions noted.
CC1.2.2	The company's board of directors meets quarterly and maintains formal meeting minutes.	Inspected the board of directors meeting minutes to determine that the company's board of directors met quarterly and maintained formal meeting minutes.	No exceptions noted.

Asad Manor asad@cloudcontrolled.com 2025-04-11T 6:18:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ENVIRONMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC1.2.3	The company's board of directors has a documented Information Security Roles and Responsibilities Policy that outlines its oversight responsibilities for internal control.	Inspected the company's Information Security Roles and Responsibilities Policy to determine that the company's board of directors had a documented Information Security Roles and Responsibilities Policy that outlined its oversight responsibilities for internal control.	No exceptions noted.
CC1.2.4	The board includes directors that are independent of the company.	Inspected the board of directors listing to determine that the company's board of directors consisted of members that were independent of the company.	No exceptions noted.
CC1.3 - COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.			
CC1.3.1	The company maintains an organizational chart that describes the organizational structure and reporting lines.	Inspected the company's organizational chart to determine that the company maintained an organizational chart that described the organizational structure and reporting lines.	No exceptions noted.
CC1.3.2	Roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls are formally assigned in the Information Security Roles and Responsibilities Policy.	Inspected the company's Information Security Roles and Responsibilities Policy to determine roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls were formally assigned in the Information Security Roles and Responsibilities Policy.	No exceptions noted.

Asal Mansour - asal@cloudsecurityportfolio.com - 2025-11-13 09:06:52

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ENVIRONMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC1.3.3	The company requires employees and contractors to review and acknowledge the information security policies at the time of hire.	Inspected the information security policies acknowledgment for a sample of new employees and contractors to determine that the information security policies were acknowledged at the time of hire.	No exceptions noted.
CC1.4 - COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.			
CC1.4.1	The company performs background checks on new employees.	Inspected the completed background check for a sample of new employees to determine whether the company performed background checks on new employees.	No exceptions noted.
CC1.4.2	The company's managers are required to complete performance evaluations for direct reports at least annually.	Inspected the completed performance evaluation for a sample of employees to determine that the company's managers were required to complete performance evaluations for direct reports annually.	No exceptions noted.
CC1.4.3	Roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls are formally assigned in the Information Security Roles and Responsibilities Policy.	Inspected the company's Information Security Roles and Responsibilities Policy to determine roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls were formally assigned in the Information Security Roles and Responsibilities Policy.	No exceptions noted.

Asaf.Mansour.asad@cloudcontrolledcom 2025-04-11T16:08:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ENVIRONMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC1.4.4	The company requires employees to complete security awareness training within thirty days of hire and at least annually thereafter.	Inspected the security awareness training topics to determine that the security awareness training covered areas to educate personnel on information security topics and the latest trends to protect sensitive data.	No exceptions noted.
		Inspected the training records for a sample of new employees and contractors to determine that the company required employees and contractors to complete security awareness training at the time of hire.	No exceptions noted.
		Inspected the training records for a sample of active employees and contractors to determine that the company required employees and contractors to complete security awareness training annually.	No exceptions noted.
CC1.5 - COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.			
CC1.5.1	The company has an approved Code of Conduct that is reviewed annually and updated as needed. Sanction policies are	Inspected the company's Code of Conduct to determine that the company had an approved Code of Conduct that was reviewed annually and updated as needed.	No exceptions noted.

Asad Mahmood asad@cloudcontroltower.com 02-04-2026 Trial 9,665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ENVIRONMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
	documented within the information security policies and procedures.	Inspected the company's information security policies and procedures to determine that sanction policies were documented within the information security policies and procedures.	No exceptions noted.
CC1.5.2	The company requires employees and contractors to acknowledge the Code of Conduct at the time of hire.	Inspected the Code of Conduct acknowledgment for a sample of new employees and contractors to determine that the Code of Conduct was acknowledged at the time of hire.	No exceptions noted.
CC1.5.3	The company's managers are required to complete performance evaluations for direct reports at least annually.	Inspected the completed performance evaluation for a sample of employees to determine that the company's managers were required to complete performance evaluations for direct reports annually.	No exceptions noted.
CC1.5.4	Roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls are formally assigned in the Information Security Roles and Responsibilities Policy.	Inspected the company's Information Security Roles and Responsibilities Policy to determine roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls were formally assigned in the Information Security Roles and Responsibilities Policy.	No exceptions noted.

Asad Mansoor, asad@cloudcomputdlc.com, 2025-04-17T 6:08:09.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ENVIRONMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC1.5.5	The company requires employees to complete security awareness training within thirty days of hire and at least annually thereafter.	Inspected the security awareness training topics to determine that the security awareness training covered areas to educate personnel on information security topics and the latest trends to protect sensitive data.	No exceptions noted.
		Inspected the training records for a sample of new employees and contractors to determine that the company required employees and contractors to complete security awareness training at the time of hire.	No exceptions noted.
		Inspected the training records for a sample of active employees and contractors to determine that the company required employees and contractors to complete security awareness training annually.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolcorp.com 2025-04-17 17:03:39.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
COMMUNICATION AND INFORMATION			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC2.1 - COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.			
CC2.1.1	The company's information security policies and procedures are documented and reviewed at least annually.	Inspected the company's information security policies and procedures to determine that the company's information security policies and procedures were documented and reviewed annually.	No exceptions noted.
CC2.1.2	The company performs control self-assessments at least annually to gain assurance that controls are in place and operating effectively. Corrective actions are taken based on relevant findings.	Inspected the company`s latest risk assessment and determined that control self-assessments were performed during the examination period, and corrective actions were taken based on relevant findings.	No exceptions noted.
CC2.1.3	The company utilizes a log management tool to identify events that may potentially impact the company's ability to achieve its security objectives.	Inspected the log management tool configurations to determine that the company utilized a log management tool to identify events that may potentially impact the company's ability to achieve its security objectives.	No exceptions noted.
CC2.2 - COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.			
CC2.2.1	The company has security incident response policies and procedures that are documented and communicated to authorized users.	Inspected the company's Incident Response Plan and the compliance platform to determine that the company had security incident response policies and procedures that were documented and communicated to authorized users.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
COMMUNICATION AND INFORMATION			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC2.2.2	Roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls are formally assigned in the Information Security Roles and Responsibilities Policy.	Inspected the company's Information Security Roles and Responsibilities Policy to determine roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls were formally assigned in the Information Security Roles and Responsibilities Policy.	No exceptions noted.
CC2.2.3	The company requires employees to complete security awareness training within thirty days of hire and at least annually thereafter.	Inspected the security awareness training topics to determine that the security awareness training covered areas to educate personnel on information security topics and the latest trends to protect sensitive data.	No exceptions noted.
		Inspected the training records for a sample of new employees and contractors to determine that the company required employees and contractors to complete security awareness training at the time of hire.	No exceptions noted.
		Inspected the training records for a sample of active employees and contractors to determine that the company required employees and contractors to complete security awareness training annually.	No exceptions noted.

Asad Mansoor, asad@cloudcomplyapp.com, 2022-04-11 Transaction 6652

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
COMMUNICATION AND INFORMATION			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC2.2.4	The company's information security policies and procedures are documented and reviewed at least annually.	Inspected the company's information security policies and procedures to determine that the company's information security policies and procedures were documented and reviewed annually.	No exceptions noted.
CC2.2.5	The company describes its products and services to internal and external users.	Inspected the company's website to determine that the company provided a description of its products and services to internal and external users.	No exceptions noted.
CC2.2.6	The company communicates system changes to authorized internal users.	Inspected an example communication to determine that the company communicated system changes to authorized internal users.	No exceptions noted.
CC2.3 - COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.			
CC2.3.1	The company's security commitments are communicated to customers in the Privacy Policy and Business Terms.	Inspected the Business Terms and Privacy Policy to determine that the company's security commitments were communicated to customers in the Business Terms and Privacy Policy.	No exceptions noted.
CC2.3.2	The company provides guidelines and technical support resources relating to system operations to customers.	Inspected the company's help center page and developer platform page to determine that the company provides guidelines and technical support resources relating to system operations to customers.	No exceptions noted.

Asad Hassoor, asad@cloudsecurityalliance.com, 2025-04-11 16:08:39.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
COMMUNICATION AND INFORMATION			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC2.3.3	The company describes its products and services to internal and external users.	Inspected the company's website to determine that the company provided a description of its products and services to internal and external users.	No exceptions noted.
CC2.3.4	The company has contact information on its website to allow users to report system information on failures, incidents, concerns, and other complaints to appropriate personnel.	Inspected the company's website to determine that the company had the contact information on their website to allow users to report system information on failures, incidents, concerns, and other complaints to appropriate personnel.	No exceptions noted.
CC2.3.5	The company has written agreements in place with vendors and related third parties. These agreements include security and confidentiality commitments applicable to that entity.	Inspected the Terms of Service for vendors to determine that security and confidentiality commitments were in place for vendors and related third parties.	No exceptions noted.
CC2.3.6	The company notifies customers of critical system changes that may affect their processing.	Inspected the system's release notes to determine that the company notified customers of critical system changes that may affect their processing.	No exceptions noted.

Asad Mansoor, asad@cloudcomputing.com 2024-11T 6:38:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
RISK ASSESSMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC3.1 - COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.			
CC3.1.1	The company specifies its objectives to enable the identification and assessment of risk related to the objectives.	Inspected the annual security risk assessment to determine that the company specified its objectives to enable the identification and assessment of risk related to the objectives.	No exceptions noted.
CC3.1.2	The company has a documented risk management program in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the company's Risk Management Policy to determine that the company had a documented risk management program in place that included guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
CC3.1.3	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.

Asad Mansoor asad@cloudcomplianceman.com 2025-04-17 16:08:59.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
RISK ASSESSMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC3.2 - COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.			
CC3.2.1	The company has a documented risk management program in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the company's Risk Management Policy to determine that the company had a documented risk management program in place that included guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
CC3.2.2	The company has a third-party management program in place. Components of this program include: - critical vendor inventory. - vendor's security requirements; and - Review of onboarded vendors and subservice organizations.	Inspected the company's Third-Party Management Policy to determine that the company had a third-party management program in place that included the security requirements for vendors.	No exceptions noted.
		Inspected the vendor listing to determine that the critical third-party vendor inventory was in place.	No exceptions noted.
		Inspected the onboarded vendor review to determine that a review of newly onboarded third-party vendors and subservice organizations was performed.	No exceptions noted.

Asad Mansoor, asad@cloudcomportuite.com, 2025-04-21 16:08:29.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
RISK ASSESSMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC3.2.3	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.
CC3.2.4	The company tests its incident response plan at least annually.	Inspected the company's Incident Response Plan to determine that the incident response plan was in place and approved by management.	No exceptions noted.
		Inspected the company's incident response plan test notes to determine that the company tests its incident response plan at least annually.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolstudio.com, 2022-04-11T19:58:39.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
RISK ASSESSMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC3.3 - COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.			
CC3.3.1	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.
CC3.3.2	The company has a documented risk management program in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the company's Risk Management Policy to determine that the company had a documented risk management program in place that included guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-17T10:09:39.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
RISK ASSESSMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC3.4 - COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.			
CC3.4.1	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.
CC3.4.2	The company has a documented risk management program in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the company's Risk Management Policy to determine that the company had a documented risk management program in place that included guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.

Asad Mansoor/asad@cloudcontrolstudio.com/2025-04-17T16:08:29.666Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
MONITORING ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC4.1 - COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.			
CC4.1.1	The company performs control self-assessments at least annually to gain assurance that controls are in place and operating effectively. Corrective actions are taken based on relevant findings.	Inspected the company`s latest risk assessment and determined that control self-assessments were performed during the examination period, and corrective actions were taken based on relevant findings.	No exceptions noted.
CC4.1.2	The company's penetration testing is performed at least annually. A remediation plan is developed, and changes are implemented to remediate vulnerabilities in accordance with SLAs.	Inspected the completed penetration report to determine that a penetration test was performed annually.	No exceptions noted.
		Inspected the remediation plan and tickets to determine that the remediation plan was developed, and changes were implemented to remediate vulnerabilities in accordance with SLAs.	No exceptions noted.

Asad Mansoor, asad@cloudsecurityaudit.com 2025-04-17 16:08:59.666Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
MONITORING ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC4.1.3	Host-based vulnerability scans are performed continuously on all external-facing systems. Critical and high vulnerabilities are tracked to remediation.	Inspected the configuration for the tool that continuously monitors infrastructure packages to determine that vulnerability scans were performed continuously on external-facing systems.	No exceptions noted.
		Inspected the alerts generated by the infrastructure-package vulnerability scanner to determine that critical and high vulnerabilities were tracked to remediation in accordance with SLAs.	No exceptions noted.
CC4.1.4	The company has a third-party management program in place. Components of this program include: - critical vendor inventory. - vendor's security requirements; and - Review of onboarded vendors and subservice organizations.	Inspected the company's Third-Party Management Policy to determine that the company had a third-party management program in place that included the security requirements for vendors.	No exceptions noted.
		Inspected the vendor listing to determine that the critical third-party vendor inventory was in place.	No exceptions noted.
		Inspected the onboarded vendor review to determine that a review of newly onboarded third-party vendors and subservice organizations was performed.	No exceptions noted.

Asad Mansoor, asad@cloudcomputudio.com 2025-04-1 Thomas 9:66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
MONITORING ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC4.2 - COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.			
CC4.2.1	The company performs control self-assessments at least annually to gain assurance that controls are in place and operating effectively. Corrective actions are taken based on relevant findings.	Inspected the company`s latest risk assessment and determined that control self-assessments were performed during the examination period, and corrective actions were taken based on relevant findings.	No exceptions noted.
CC4.2.2	The company has a third-party management program in place. Components of this program include: - critical vendor inventory. - vendor's security requirements; and - Review of onboarded vendors and subservice organizations.	Inspected the company's Third-Party Management Policy to determine that the company had a third-party management program in place that included the security requirements for vendors.	No exceptions noted.
		Inspected the vendor listing to determine that the critical third-party vendor inventory was in place.	No exceptions noted.
		Inspected the onboarded vendor review to determine that a review of newly onboarded third-party vendors and subservice organizations was performed.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolled.com 2025-04-17T18:08:29.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
MONITORING ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC4.2.3	The company's penetration testing is performed at least annually. A remediation plan is developed, and changes are implemented to remediate vulnerabilities in accordance with SLAs.	Inspected the completed penetration report to determine that a penetration test was performed annually.	No exceptions noted.
		Inspected the remediation plan and tickets to determine that the remediation plan was developed, and changes were implemented to remediate vulnerabilities in accordance with SLAs.	No exceptions noted.
CC4.2.4	Host-based vulnerability scans are performed continuously on all external-facing systems. Critical and high vulnerabilities are tracked to remediation.	Inspected the configuration for the tool that continuously monitors infrastructure packages to determine that vulnerability scans were performed continuously on external-facing systems.	No exceptions noted.
		Inspected the alerts generated by the infrastructure-package vulnerability scanner to determine that critical and high vulnerabilities were tracked to remediation in accordance with SLAs.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolled.com, 2025-04-11T16:18:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC5.1 - COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.			
CC5.1.1	The company has a documented risk management program in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the company's Risk Management Policy to determine that the company had a documented risk management program in place that included guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
CC5.1.2	The company's information security policies and procedures are documented and reviewed at least annually.	Inspected the company's information security policies and procedures to determine that the company's information security policies and procedures were documented and reviewed annually.	No exceptions noted.
CC5.1.3	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.

Asaf Malchor, asaf@cloudcomplianceportal.com, 2025-04-11 16:08:29.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC5.1.4	Role-based access is configured within Azure, GitHub, and other supporting applications to enforce the segregation of duties and restrict access to confidential information.	Inspected the system configuration for Azure, GitHub, and other supporting applications to determine that role-based access was configured within Azure, GitHub, and other supporting applications to enforce segregation of duties and restrict access to confidential information.	No exceptions noted.
CC5.2 - COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.			
CC5.2.1	The company's Access Control Policy documents the requirements for the following access control functions: - adding new users; - modifying users; and/or - removing an existing user's access.	Inspected the company's Access Control Policy to determine that the Access Control Policy documented the requirements for adding, modifying, and removing user access.	No exceptions noted.
CC5.2.2	The company has a formal systems development life cycle (SDLC) methodology in place that governs the development, acquisition, implementation, changes (including emergency changes), and maintenance of information systems and related technology requirements.	Inspected the company's Operations Security and Secure Development policies to determine that the company had a formal SDLC methodology in place that governed the development, acquisition, implementation, changes (including emergency changes), and maintenance of information systems and related technology requirements.	No exceptions noted.

Asad Masood asad@cloudcomplianceportfolio.com 2024-01-11 12:09:06 GMT

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC5.2.3	The company's information security policies and procedures are documented and reviewed at least annually.	Inspected the company's information security policies and procedures to determine that the company's information security policies and procedures were documented and reviewed annually.	No exceptions noted.
CC5.3 - COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.			
CC5.3.1	The company's information security policies and procedures are documented and reviewed at least annually.	Inspected the company's information security policies and procedures to determine that the company's information security policies and procedures were documented and reviewed annually.	No exceptions noted.
CC5.3.2	The company requires changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	Inspected the company's Operations Security and Secure Development policies to determine that the company required changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceguy.com, 2025-04-11T16:08:09.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC5.3.2 *(cont.)*	The company requires changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	Inspected the change management documentation for a sample of changes to determine that the company required changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	No exceptions noted.
CC5.3.3	The company has a formal systems development life cycle (SDLC) methodology in place that governs the development, acquisition, implementation, changes (including emergency changes), and maintenance of information systems and related technology requirements.	Inspected the company's Operations Security and Secure Development policies to determine that the company had a formal SDLC methodology in place that governed the development, acquisition, implementation, changes (including emergency changes), and maintenance of information systems and related technology requirements.	No exceptions noted.
CC5.3.4	The company has security incident response policies and procedures that are documented and communicated to authorized users.	Inspected the company's Incident Response Plan and the compliance platform to determine that the company had security incident response policies and procedures that were documented and communicated to authorized users.	No exceptions noted.
CC5.3.5	The company specifies its objectives to enable the identification and assessment of risk related to the objectives.	Inspected the annual security risk assessment to determine that the company specified its objectives to enable the identification and assessment of risk related to the objectives.	No exceptions noted.

SAFEBASE

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC5.3.6	The company has a documented risk management program in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the company's Risk Management Policy to determine that the company had a documented risk management program in place that included guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
CC5.3.7	Roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls are formally assigned in the Information Security Roles and Responsibilities Policy.	Inspected the company's Information Security Roles and Responsibilities Policy to determine roles and responsibilities for the design, development, implementation, operation, maintenance, and monitoring of information security controls were formally assigned in the Information Security Roles and Responsibilities Policy.	No exceptions noted.
CC5.3.8	The company has a third-party management program in place. Components of this program include: - critical vendor inventory. - vendor's security requirements; and - Review of onboarded vendors and subservice organizations.	Inspected the company's Third-Party Management Policy to determine that the company had a third-party management program in place that included the security requirements for vendors.	No exceptions noted.
		Inspected the vendor listing to determine that the critical third-party vendor inventory was in place.	No exceptions noted.

Asad Mansoor, asad@cloudsecurityboost.com, 2024-07-16 08:39:06 CDT

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CONTROL ACTIVITIES			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC5.3.8 *(cont.)*	The company has a third-party management program in place. Components of this program include: - critical vendor inventory. - vendor's security requirements; and - Review of onboarded vendors and subservice organizations.	Inspected the onboarded vendor review to determine that a review of newly onboarded third-party vendors and subservice organizations was performed.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T 16:16:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.1 - The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.			
CC6.1.1	The company's Access Control Policy documents the requirements for the following access control functions: - adding new users; - modifying users; and/or - removing an existing user's access.	Inspected the company's Access Control Policy to determine that the Access Control Policy documented the requirements for adding, modifying, and removing user access.	No exceptions noted.
CC6.1.2	The company has a Data Classification Policy in place to help ensure that confidential data is properly secured and restricted to authorized personnel.	Inspected the company's Data Management Policy to determine that the company had a Data Management Policy in place to help ensure that confidential data was properly secured and restricted to authorized personnel.	No exceptions noted.
CC6.1.3	The company's databases housing sensitive customer data are encrypted at rest.	Inspected the encryption configurations to determine that the company databases housing sensitive customer data are encrypted at rest.	No exceptions noted.
CC6.1.4	The company restricts privileged access to encryption keys to authorized users with a business need.	Inspected the company's Cryptography Policy to determine that the company restricted privileged access to encryption keys to authorized users with a business need.	No exceptions noted.
		Inspected the list of users with privileged access to encryption keys to determine that the company restricted privileged access to authorized users with a business need.	No exceptions noted.

Asad Mansour, asad@cloudcontrolstudio.com, 2025-04-17 16:39:06Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.1.5	Role-based access is configured within Azure, GitHub, and other supporting applications to enforce the segregation of duties and restrict access to confidential information.	Inspected the system configuration for Azure, GitHub, and other supporting applications to determine that role-based access was configured within Azure, GitHub, and other supporting applications to enforce segregation of duties and restrict access to confidential information.	No exceptions noted.
CC6.1.6	The company restricts privileged access to the network, application, databases, and supporting cloud infrastructure to authorized users with a business need.	Inspected the list of users with privileged access to the cloud infrastructure and application to determine that the company restricted privileged access to the network, application, databases, and supporting cloud infrastructure to authorized users with a business need.	No exceptions noted.
CC6.1.7	The company restricts privileged access to the firewall to authorized users with a business need.	Inspected the list of users with privileged access to the firewall to determine that the company restricted privileged access to the firewall to authorized users with a business need.	No exceptions noted.
CC6.1.8	The firewall is configured to prevent unauthorized access to the company's network.	Inspected the firewall rules to determine that the firewall was configured to prevent unauthorized access to the company's network.	No exceptions noted.
CC6.1.9	The company ensures that new user access to in-scope system components is based on job role and function.	Inspected the user access request and in-scope user listings for a sample of new employees and contractors to determine that the company ensured that user access to in-scope system components was based on job role and function.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolsupport.com 2024-04-11T19:09:06Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.1.10	The company requires passwords for in-scope system components to be configured according to the company's policy.	Inspected the password configurations and written password policy to determine that the company required passwords for in-scope system components to be configured according to the company's policy.	No exceptions noted.
CC6.1.11	The company's production systems can only be remotely accessed by authorized employees possessing a valid multi-factor authentication (MFA) method.	Inspected the MFA configurations to determine that the company's production systems could only be remotely accessed by authorized employees possessing a valid MFA method.	No exceptions noted.
CC6.1.12	The company's production systems can only be remotely accessed by authorized employees via an approved encrypted connection.	Inspected the company's Infrastructure as a Service provider's TLS certificate to determine that the company's production systems could only be remotely accessed by authorized employees via an approved encrypted connection.	No exceptions noted.
CC6.1.13	The company maintains a formal inventory of production system assets.	Inspected an inventory listing of information assets to determine that the company maintained a formal inventory of production system assets.	No exceptions noted.
CC6.1.14	The company's network is segmented to prevent unauthorized access to customer data.	Inspected the network diagram to determine that the company's network was segmented to prevent unauthorized access to customer data.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceportal.com 2025-04-11 Thu 19:16 CT

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.2 - Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.			
CC6.2.1	The company's Access Control Policy documents the requirements for the following access control functions: - adding new users; - modifying users; and/or - removing an existing user's access.	Inspected the company's Access Control Policy to determine that the Access Control Policy documented the requirements for adding, modifying, and removing user access.	No exceptions noted.
CC6.2.2	The company conducts quarterly access reviews for the in-scope system components to help ensure that access is restricted appropriately. Required changes are tracked to completion.	Inspected the user access review documentation to determine that the company conducted quarterly access reviews for the in-scope system components to help ensure that access was restricted appropriately.	No exceptions noted.
CC6.2.3	Logical access to systems is revoked as a component of the termination process within the company's SLAs.	Inspected the user access and offboarding checklist and in-scope user listings for a sample of terminated employees and contractors to determine that logical access to systems was revoked as a component of the termination process within the company's SLAs.	No exceptions noted.
CC6.2.4	The company ensures that new user access to in-scope system components is based on job role and function.	Inspected the user access request and in-scope user listings for a sample of new employees and contractors to determine that the company ensured that user access to in-scope system components was based on job role and function.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceup.com, 2025-04-17 18:08:29 66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.3 - The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.			
CC6.3.1	The company's Access Control Policy documents the requirements for the following access control functions: - adding new users; - modifying users; and/or - removing an existing user's access.	Inspected the company's Access Control Policy to determine that the Access Control Policy documented the requirements for adding, modifying, and removing user access.	No exceptions noted.
CC6.3.2	The company conducts quarterly access reviews for the in-scope system components to help ensure that access is restricted appropriately. Required changes are tracked to completion.	Inspected the user access review documentation to determine that the company conducted quarterly access reviews for the in-scope system components to help ensure that access was restricted appropriately.	No exceptions noted.
CC6.3.3	Logical access to systems is revoked as a component of the termination process within the company's SLAs.	Inspected the user access and offboarding checklist and in-scope user listings for a sample of terminated employees and contractors to determine that logical access to systems was revoked as a component of the termination process within the company's SLAs.	No exceptions noted.
CC6.3.4	The company ensures that new user access to in-scope system components is based on job role and function.	Inspected the user access request and in-scope user listings for a sample of new employees and contractors to determine that the company ensured that user access to in-scope system components was based on job role and function.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceup.com, 2025-04-17T16:08:29.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.4 - The entity restricts physical access to facilities and protected information assets (for example, data center facilities, backup media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.			
CC6.4.1	Management contracts with Microsoft using their Microsoft Azure to provide physical access security of its production systems.	This control activity is the responsibility of the subservice organization. Refer to the Subservice Organization section above for controls managed by the subservice organization.	
CC6.5 - The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.			
CC6.5.1	The company has formal retention and disposal procedures in place to guide the secure retention and disposal of company and customer data.	Inspected the data retention and disposal procedures to determine that the company had formal retention and disposal procedures in place to guide the secure retention and disposal of company and customer data.	No exceptions noted.
CC6.5.2	The company has electronic media containing confidential information purged or destroyed in accordance with best practices.	Inspected a data deletion record for a sample of data and media disposals to determine that the company had electronic media containing confidential information purged or destroyed in accordance with best practices.	No exceptions noted.
CC6.5.3	The destruction of physical assets hosting the production environment is the responsibility of Azure.	This control activity is the responsibility of the subservice organization. Refer to the Subservice Organization section above for controls managed by the subservice organization.	

Asad Mansoor, asad@cloudcontrolstudio.com 2025-4-7 16:08:29.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.6 - The entity implements logical access security measures to protect against threats from sources outside its system boundaries.			
CC6.6.1	The company's production systems can only be remotely accessed by authorized employees via an approved encrypted connection.	Inspected the company's Infrastructure as a Service provider's TLS certificate to determine that the company's production systems could only be remotely accessed by authorized employees via an approved encrypted connection.	No exceptions noted.
CC6.6.2	The company's production systems can only be remotely accessed by authorized employees possessing a valid multi-factor authentication (MFA) method.	Inspected the MFA configurations to determine that the company's production systems could only be remotely accessed by authorized employees possessing a valid MFA method.	No exceptions noted.
CC6.6.3	The firewall is configured to prevent unauthorized access to the company's network.	Inspected the firewall rules to determine that the firewall was configured to prevent unauthorized access to the company's network.	No exceptions noted.
CC6.6.4	The company uses secure data transmission protocols to encrypt confidential and sensitive data when transmitted over public networks.	Inspected the company's website and TLS certificate to determine that the company used secure data transmission protocols to encrypt confidential and sensitive data when transmitted over public networks.	No exceptions noted.

Asad Mansoor, asad@cloudsecurityprotude.com, 2025-04-17T16:08:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.6.5	The company uses an Intrusion Detection System (IDS) to provide continuous monitoring of the company's network and early detection of potential security breaches.	Inspected the IDS configurations to determine that the company used an IDS to provide continuous monitoring of the company's network and early detection of potential security breaches.	No exceptions noted.
CC6.7 - The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.			
CC6.7.1	The company encrypts portable devices when used.	Inspected the company's Cryptography Policy to determine that the company encrypted portable devices when used.	No exceptions noted.
		Inspected the encryption configurations to determine that the company encrypted portable media devices when used.	No exceptions noted.
CC6.7.2	The company uses secure data transmission protocols to encrypt confidential and sensitive data when transmitted over public networks.	Inspected the company's website and TLS certificate to determine that the company used secure data transmission protocols to encrypt confidential and sensitive data when transmitted over public networks.	No exceptions noted.
CC6.7.3	The company has a mobile device monitoring system in place to centrally monitor mobile devices supporting the service.	Inspected the company's mobile device monitoring system to determine that the company had a mobile device monitoring system in place to centrally monitor mobile devices supporting the service.	No exceptions noted.

Asad Mansoor, asad@cloudsecurityaudit.com 2025-04-17T20:59:46.6Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
LOGICAL AND PHYSICAL ACCESS CONTROLS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC6.8 - The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.			
CC6.8.1	The company deploys anti-malware technology to environments commonly susceptible to malicious attacks. The anti-malware software is configured to scan workstations daily and install updates as new updates/signatures are available.	Inspected the anti-malware configurations to determine that the company deployed anti-malware technology to environments commonly susceptible to malicious attacks.	No exceptions noted.
		Inspected the anti-malware configurations to determine that the anti-malware software was configured to scan workstations daily and install updates as new updates were available.	No exceptions noted.
CC6.8.2	The company has a formal systems development life cycle (SDLC) methodology in place that governs the development, acquisition, implementation, changes (including emergency changes), and maintenance of information systems and related technology requirements.	Inspected the company's Operations Security and Secure Development policies to determine that the company had a formal SDLC methodology in place that governed the development, acquisition, implementation, changes (including emergency changes), and maintenance of information systems and related technology requirements.	No exceptions noted.

Asad Mansoor, asad@cloudsecuritystudio.com 2024-04-17T16:08:29.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.1 - To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.			
CC7.1.1	The company requires changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	Inspected the company's Operations Security and Secure Development policies to determine that the company required changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	No exceptions noted.
		Inspected the change management documentation for a sample of changes to determine that the company required changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceop.com 2025-04-17T16:08:29.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.1.2	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.
CC7.1.3	Host-based vulnerability scans are performed continuously on all external-facing systems. Critical and high vulnerabilities are tracked to remediation.	Inspected the configuration for the tool that continuously monitors infrastructure packages to determine that vulnerability scans were performed continuously on external-facing systems.	No exceptions noted.
		Inspected the alerts generated by the infrastructure-package vulnerability scanner to determine that critical and high vulnerabilities were tracked to remediation in accordance with SLAs.	No exceptions noted.

Asad Mansoor, asad@clouditstudio.com, 2022-04-11 18:08:39.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.1.4	The company's penetration testing is performed at least annually. A remediation plan is developed, and changes are implemented to remediate vulnerabilities in accordance with SLAs.	Inspected the completed penetration report to determine that a penetration test was performed annually.	No exceptions noted.
		Inspected the remediation plan and tickets to determine that the remediation plan was developed, and changes were implemented to remediate vulnerabilities in accordance with SLAs.	No exceptions noted.
CC7.1.5	The company has a configuration management procedure in place to ensure that system configurations are deployed consistently throughout the environment.	Inspected the company's Operations Security Policy to determine that the company had a configuration management procedure in place to ensure that system configurations were deployed consistently throughout the environment.	No exceptions noted.
CC7.1.6	The company's formal policies outline the requirements for the following functions related to IT / Engineering: - vulnerability management; - system monitoring.	Inspected the company's Operations Security Policy to determine that the company's formal policies outlined the requirements for vulnerability management and system monitoring.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceportal.com, 2025-04-11T16:08:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.2 - The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.			
CC7.2.1	The company uses an Intrusion Detection System (IDS) to provide continuous monitoring of the company's network and early detection of potential security breaches.	Inspected the IDS configurations to determine that the company used an IDS to provide continuous monitoring of the company's network and early detection of potential security breaches.	No exceptions noted.
CC7.2.2	The company utilizes a log management tool to identify events that may potentially impact the company's ability to achieve its security objectives.	Inspected the log management tool configurations to determine that the company utilized a log management tool to identify events that may potentially impact the company's ability to achieve its security objectives.	No exceptions noted.
CC7.2.3	The company's formal policies outline the requirements for the following functions related to IT / Engineering: - vulnerability management; - system monitoring.	Inspected the company's Operations Security Policy to determine that the company's formal policies outlined the requirements for vulnerability management and system monitoring.	No exceptions noted.
CC7.2.4	An infrastructure monitoring tool is utilized to monitor systems, infrastructure, and performance and generates alerts when specific predefined thresholds are met.	Inspected the monitoring tool configurations to determine that an infrastructure monitoring tool was utilized to monitor systems, infrastructure, and performance and generated alerts when specific predefined thresholds were met.	No exceptions noted.

Asad Warraich, asad@cloudcomplianceinc.com, 2025-04-17T16:08:39.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.2.5	Host-based vulnerability scans are performed continuously on all external-facing systems. Critical and high vulnerabilities are tracked to remediation.	Inspected the configuration for the tool that continuously monitors infrastructure packages to determine that vulnerability scans were performed continuously on external-facing systems.	No exceptions noted.
		Inspected the alerts generated by the infrastructure-package vulnerability scanner to determine that critical and high vulnerabilities were tracked to remediation in accordance with SLAs.	No exceptions noted.
CC7.2.6	The company's penetration testing is performed at least annually. A remediation plan is developed, and changes are implemented to remediate vulnerabilities in accordance with SLAs.	Inspected the completed penetration report to determine that a penetration test was performed annually.	No exceptions noted.
		Inspected the remediation plan and tickets to determine that the remediation plan was developed, and changes were implemented to remediate vulnerabilities in accordance with SLAs.	No exceptions noted.
CC7.2.7	Security incidents are reported to the IT personnel and tracked through to resolution in a ticketing system.	Inspected the incident ticket for a sample of security incidents to determine that security incidents were reported to the IT personnel and tracked through to resolution in a ticketing system.	No exceptions noted.

Asad Mansoor, asad@cloudcomplytudio.com 2025-04-1 T08:59:06Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.3 - The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.			
CC7.3.1	The company has security incident response policies and procedures that are documented and communicated to authorized users.	Inspected the company's Incident Response Plan and the compliance platform to determine that the company had security incident response policies and procedures that were documented and communicated to authorized users.	No exceptions noted.
CC7.3.2	The company's security incidents are logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	Inspected the company's Operations Security Policy and Incident Response Plan to determine that the company's security incidents were logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	No exceptions noted.
		Inspected the incident ticket for a sample of incidents to determine that the company's security incidents are logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceprofessionals.com

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.4 - The entity responds to identified security incidents by executing a defined incident-response program to understand, contain, remediate, and communicate security incidents, as appropriate.			
CC7.4.1	The company has security incident response policies and procedures that are documented and communicated to authorized users.	Inspected the company's Incident Response Plan and the compliance platform to determine that the company had security incident response policies and procedures that were documented and communicated to authorized users.	No exceptions noted.
CC7.4.2	The company's security incidents are logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	Inspected the company's Operations Security Policy and Incident Response Plan to determine that the company's security incidents were logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	No exceptions noted.
		Inspected the incident ticket for a sample of incidents to determine that the company's security incidents are logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	No exceptions noted.
CC7.4.3	The company tests its incident response plan at least annually.	Inspected the company's Incident Response Plan to determine that the incident response plan was in place and approved by management.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceprofessionals.com 02-24 17:08:39.667Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.4.3 (*Cont.*)	The company tests its incident response plan at least annually.	Inspected the company's incident response plan test notes to determine that the company tests its incident response plan at least annually.	No exceptions noted.
CC7.5 - The entity identifies, develops, and implements activities to recover from identified security incidents.			
CC7.5.1	The company has security incident response policies and procedures that are documented and communicated to authorized users.	Inspected the company's Incident Response Plan and the compliance platform to determine that the company had security incident response policies and procedures that were documented and communicated to authorized users.	No exceptions noted.
CC7.5.2	The company's security incidents are logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	Inspected the company's Operations Security Policy and Incident Response Plan to determine that the company's security incidents were logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	No exceptions noted.
		Inspected the incident ticket for a sample of incidents to determine that the company's security incidents are logged, tracked, resolved, and communicated to affected or relevant parties by management according to the company's security incident response policy and procedures.	No exceptions noted.

Asad Mansoor, asad@closingtostudio.com 2025-04-17 16:08:59 GMT

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
SYSTEM OPERATIONS			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC7.5.3	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.
CC7.5.4	The company tests its incident response plan at least annually.	Inspected the company's Incident Response Plan to determine that the incident response plan was in place and approved by management.	No exceptions noted.
		Inspected the company's incident response plan test notes to determine that the company tests its incident response plan at least annually.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolstudio.com, 2022-04-11T19:58:39.665Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CHANGE MANAGEMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC8.1 - The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.			
CC8.1.1	The company has a formal systems development life cycle (SDLC) methodology in place that governs the development, acquisition, implementation, changes (including emergency changes), and maintenance of information systems and related technology requirements.	Inspected the company's Operations Security and Secure Development policies to determine that the company had a formal SDLC methodology in place that governed the development, acquisition, implementation, changes (including emergency changes), and maintenance of information systems and related technology requirements.	No exceptions noted.
CC8.1.2	The company requires changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	Inspected the company's Operations Security and Secure Development policies to determine that the company required changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	No exceptions noted.
		Inspected the change management documentation for a sample of changes to determine that the company required changes to software and infrastructure components of the service to be authorized, formally documented, tested, reviewed, and approved before being implemented in the production environment.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceop.com 2025-04-11T08:39:06Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CHANGE MANAGEMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC8.1.3	Segregation of duties is in place to prevent developers from pushing changes to production.	Inspected the user listing for the company's change management tool to determine that developers do not have access to the production environment.	No exceptions noted.
CC8.1.4	The company restricts access to the production environment to authorized personnel.	Inspected the users with access to production to determine that the company restricts access to the production environment to authorized personnel.	No exceptions noted.
CC8.1.5	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.

Asad Mansoor, asad@cloudcomplianceauditor.com, 2025-04-11T16:08:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
CHANGE MANAGEMENT			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC8.1.6	The company's penetration testing is performed at least annually. A remediation plan is developed, and changes are implemented to remediate vulnerabilities in accordance with SLAs.	Inspected the completed penetration report to determine that a penetration test was performed annually.	No exceptions noted.
		Inspected the remediation plan and tickets to determine that the remediation plan was developed, and changes were implemented to remediate vulnerabilities in accordance with SLAs.	No exceptions noted.
CC8.1.7	Host-based vulnerability scans are performed continuously on all external-facing systems. Critical and high vulnerabilities are tracked to remediation.	Inspected the configuration for the tool that continuously monitors infrastructure packages to determine that vulnerability scans were performed continuously on external-facing systems.	No exceptions noted.
		Inspected the alerts generated by the infrastructure-package vulnerability scanner to determine that critical and high vulnerabilities were tracked to remediation in accordance with SLAs.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolled.com, 2025-04-17T16:08:59.66Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
RISK MITIGATION			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC9.1 - The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.			
CC9.1.1	The company's risk assessments are performed at least annually. As part of this process, threats, and changes (environmental, regulatory, and technological) to service commitments are identified and the risks are formally assessed. The risk assessment includes a consideration of the potential for fraud and how fraud may impact the achievement of objectives.	Inspected the annual security risk assessment to determine that the company performed a risk assessment annually that included the identification and assessment of threats and changes to services commitments, a consideration of the potential for fraud, and how fraud may impact the achievement of objectives.	No exceptions noted.
CC9.1.2	The company has a documented risk management program in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	Inspected the company's Risk Management Policy to determine that the company had a documented risk management program in place that included guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks.	No exceptions noted.
CC9.2 - The entity assesses and manages risks associated with vendors and business partners.			
CC9.2.1	The company has written agreements in place with vendors and related third parties. These agreements include security and confidentiality commitments applicable to that entity.	Inspected the Terms of Service for vendors to determine that security and confidentiality commitments were in place for vendors and related third parties.	No exceptions noted.

Ana Mansoor, sad@cloudcontrolstudio.com, 2025-04-17 16:08:29.666Z

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY			
RISK MITIGATION			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
CC9.2.2	The company has a third-party management program in place. Components of this program include: - critical vendor inventory. - vendor's security requirements; and - Review of onboarded vendors and subservice organizations.	Inspected the company's Third-Party Management Policy to determine that the company had a third-party management program in place that included the security requirements for vendors.	No exceptions noted.
		Inspected the vendor listing to determine that the critical third-party vendor inventory was in place.	No exceptions noted.
		Inspected the onboarded vendor review to determine that a review of newly onboarded third-party vendors and subservice organizations was performed.	No exceptions noted.

Asad Mansoor, asad@cloudconsortium.com, 2025-04-17 08:39:66Z

ADDITIONAL CRITERIA FOR THE CONFIDENTIALITY CATEGORY			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
C1.1 - The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.			
C1.1.1	The company has written agreements in place with vendors and related third parties. These agreements include security and confidentiality commitments applicable to that entity.	Inspected the Terms of Service for vendors to determine that security and confidentiality commitments were in place for vendors and related third parties.	No exceptions noted.
C1.1.2	The company has formal retention and disposal procedures in place to guide the secure retention and disposal of company and customer data.	Inspected the data retention and disposal procedures to determine that the company had formal retention and disposal procedures in place to guide the secure retention and disposal of company and customer data.	No exceptions noted.
C1.1.3	The company has a Data Classification Policy in place to help ensure that confidential data is properly secured and restricted to authorized personnel.	Inspected the company's Data Management Policy to determine that the company had a Data Management Policy in place to help ensure that confidential data was properly secured and restricted to authorized personnel.	No exceptions noted.
C1.1.4	The company restricts privileged access to the network, application, databases, and supporting cloud infrastructure to authorized users with a business need.	Inspected the list of users with privileged access to the cloud infrastructure and application to determine that the company restricted privileged access to the network, application, databases, and supporting cloud infrastructure to authorized users with a business need.	No exceptions noted.

Asad Mansoor, asad@cloudsecurityalliance.org 2025-04-11T16:18:30.985Z

ADDITIONAL CRITERIA FOR THE CONFIDENTIALITY CATEGORY			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
C1.1.5	Role-based access is configured within Azure, GitHub, and other supporting applications to enforce the segregation of duties and restrict access to confidential information.	Inspected the system configuration for Azure, GitHub, and other supporting applications to determine that role-based access was configured within Azure, GitHub, and other supporting applications to enforce segregation of duties and restrict access to confidential information.	No exceptions noted.
C1.1.6	The company prohibits confidential or sensitive customer data, by policy, from being used or stored in non-production systems/environments.	Inspected the company's Secure Development Policy to determine that the company prohibited confidential or sensitive customer data, by policy, from being used or stored in non-production systems/environments.	No exceptions noted.
		Inspected the example test data to determine that the company prohibited confidential or sensitive customer data, by policy, from being used or stored in non-production systems/environments.	No exceptions noted.
C1.2 - The entity disposes of confidential information to meet the entity's objectives related to confidentiality.			
C1.2.1	The company has formal retention and disposal procedures in place to guide the secure retention and disposal of company and customer data.	Inspected the data retention and disposal procedures to determine that the company had formal retention and disposal procedures in place to guide the secure retention and disposal of company and customer data.	No exceptions noted.

Asad Mansoor, asad@cloudpresstudio.com 2025-04-17 10:03:06 UTC

ADDITIONAL CRITERIA FOR THE CONFIDENTIALITY CATEGORY			
Control Number	**Controls**	**Detailed Tests of Controls**	**Test Results**
C1.2.2	The company has electronic media containing confidential information purged or destroyed in accordance with best practices.	Inspected a data deletion record for a sample of data and media disposals to determine that the company had electronic media containing confidential information purged or destroyed in accordance with best practices.	No exceptions noted.

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-17 [illegible]